

‘internal’ safe zone. Even if a request comes from inside the office network, trust is never granted implicitly based on location. Instead, every single communication is evaluated and secured on a per-session or per-transaction basis, ensuring that authentication and authorisation happen right before the resource is accessed.

When it comes to access, the principle of ‘Least Privilege’ is strictly enforced to stop attackers from roaming freely. Instead of giving blanket permissions to a whole network segment, we provide the absolute minimum access like ‘read’ or ‘write’ needed for a specific task. This ensures that even if a subject gets into one resource, they don’t automatically get the keys to everything else in the enterprise.

‘Identity and Contextual Awareness’ take security beyond just checking a username and password. The system looks at a dynamic mix of ‘who’ is asking and ‘how’ they are asking, including the subject’s identity, the device’s security posture (like patch levels), geolocation, and even the time of the request. By analysing these behavioural and environmental attributes, the trust algorithm can decide if the risk level is acceptable for that specific moment.

Finally, ‘Microsegmentation’ is the technical way infrastructure is broken into small, protected zones. We place individual resources or small groups of apps on their own unique segments, guarded by gateway security components or ‘Policy Enforcement Points’. This is critical for protecting ‘East-West’ traffic and preventing lateral movement, as it ensures that even if one service is compromised, the attacker is stuck in that single segment and cannot reach other crown jewel applications.

The technical blueprint (NIST logical components)

In this setup (Figure 1), the Policy Engine (PE) and Policy Administrator (PA) act as the ‘Brain’ of the operation,

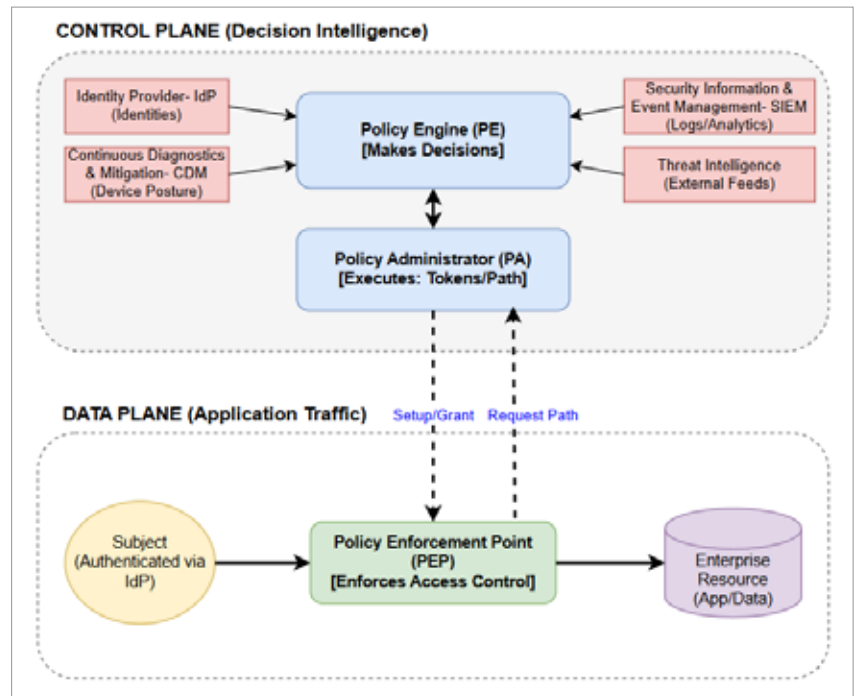


Figure 1: Core technical blueprint

together forming what we call the Policy Decision Point (PDP). The PE is the actual decision-maker that uses a trust algorithm to grant, deny, or even revoke access based on enterprise policies and external data feeds. Once the PE makes a call, the PA takes over to execute that decision by establishing or shutting down the communication path between the subject and the resource.

Next, we have the Policy Enforcement Point (PEP), which serves as the ‘Gatekeeper’ that sits in the line of traffic. This is the system responsible for enabling, monitoring, and eventually terminating the connections. In a real-world deployment, the PEP is often split into two parts: a device agent on the user’s laptop and a resource gateway sitting right in front of the application or database to ensure only authorised traffic gets through.

A very important technical requirement here is the separation of planes. We keep the control plane, where our PDP and PEP communicate to manage and configure the network, logically separate from the data plane,

which carries the actual application and service workload. By doing this, we ensure that no application traffic can flow until the path has been explicitly established and secured via the control plane.

To make the whole system ‘smart’, we integrate telemetry and automation using various data sources. We use Continuous Diagnostics and Mitigation (CDM) systems to keep an eye on device health and patch levels, while Security Information & Event Management (SIEM) and Threat Intelligence (TI) systems aggregate all network and system activity logs for real-time feedback. This centralised telemetry allows the policy engine to make high-confidence decisions and react to threats automatically as they happen.

Zero Trust (ZT) principles mapped to NIST components

Never trust, always verify: This ZT principle eliminates the idea of a trusted internal network. Every request, whether it is from inside or outside, is